CVEs más relevantes de la semana

Del 03/10/2026 al 10/10/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-106218

Descripción: In JetBrains TeamCity before 2026.1.3 2025.11.7 kotlin DSL sandbox escape leading to RCE on the server was possible

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-184

Tecnología: No especificado

Publicado el: 2026-10-06

CVE-2026-106195

Descripción: Incorrect authorization in Chromoting in Google Chrome on on Mac prior to 155.0.8059.39 allowed a remote attacker to bypass system access restrictions via crafted network traffic. (Chromium security severity: Low)

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-10-06

CVE-2026-106237

Descripción: Information leak in Permissions in Google Chrome prior to 155.0.8059.39 allowed a remote attacker to bypass site isolation via a crafted HTML page. (Chromium security severity: Low)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:L

Tipo: CWE-200

Tecnología: No especificado

Publicado el: 2026-10-06

CVE-2026-93675

Descripción: IBM Langflow OSS 1.0.0 through 1.12.2 could allow a remote attacker to execute arbitrary code due to an expected dependency confusion.

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-440

Tecnología: No especificado

Publicado el: 2026-10-07

CVE-2026-76454

Descripción: A vulnerability in the Cisco Smart Licensing Utility API of Cisco License On-Prem, formerly Cisco Smart Software Manager On-Prem (SSM On-Prem), could allow an unauthenticated, remote attacker to write arbitrary files to the system or cause a DoS condition on an affected application. This vulnerability is due to improper input validation and a lack of authentication in the management API. An ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-23

Tecnología: No especificado

Publicado el: 2026-10-07

CVE-2026-76459

Descripción: As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco NX-OS engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening release that addresses multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-76459 are related to out-of-bounds write issues that are grouped und...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-10-07

CVE-2026-107699

Descripción: ppt2png through 0.0.6 contains an OS command injection vulnerability that allows attackers to execute operating system commands by supplying unsanitized input or output path arguments. Attackers can append shell metacharacters such as ';' to file names passed to child_process.exec() in ppt2png.js, running commands with Node.js process privileges.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-08

CVE-2026-104075

Descripción: TVU Networks Receiver/Transceiver devices running firmware before version 7.9 contain an authentication bypass vulnerability in the web management login endpoint POST /tvu/Login that allows remote unauthenticated attackers to obtain an administrative session by submitting an empty or absent UserName parameter. Attackers can send a crafted HTTP request directly, bypassing client-side JavaScript ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-10-08

CVE-2026-82334

Descripción: IBM Guardium Data Protection 12.0, 12.1, 12.2 is vulnerable to a heap-based out-of-bounds read in the TDS7 LOGIN7 protocol parser. A remote attacker could send a specially crafted TDS LOGIN7 packet containing invalid offset or length values, potentially causing information disclosure or denial of service.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-10-08

CVE-2026-82335

Descripción: IBM Guardium Data Protection 12.0, 12.1, 12.2 is vulnerable to a heap-based buffer overflow in the MongoDB protocol parser. A remote attacker could send a specially crafted MongoDB SCRAM username containing an excessive length and cause memory corruption, potentially resulting in denial of service or arbitrary code execution.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-10-08

CVE-2026-82344

Descripción: IBM Guardium Data Protection 12.0, 12.1 is vulnerable to a heap-based buffer overflow in the S-TAP TrafficTap TDS login reassembly functionality. An unauthenticated remote attacker can send crafted TDS login fragments that exceed the fixed-size reassembly buffer, potentially resulting in denial of service or arbitrary code execution on the affected system.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-10-08

CVE-2026-107779

Descripción: Dromara Skyeye through commit 003549ae5615bd114ba5bb8ddf6a8e8ead97c321 contains a missing authentication vulnerability in bundled xxl-job-admin JobInfoController endpoints annotated with @PermissionLimit(limit = false). Unauthenticated attackers can POST GLUE_SHELL, GLUE_PYTHON, or GLUE_POWERSHELL jobs with attacker-supplied glueSource to /jobinfo/addAndStart, executing commands on the executor...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-08

CVE-2026-107780

Descripción: Dromara Skyeye through commit 003549ae5615bd114ba5bb8ddf6a8e8ead97c321 contains an OS command injection vulnerability in the unauthenticated /post/TtsController/textToSpeech endpoint via the format parameter. Attackers can inject a single quote into format to break out of the PowerShell string and execute commands as the Skyeye service account on Windows.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-08

CVE-2026-85531

Descripción: Improper verification of cryptographic signature vulnerability in Sipay Electronic Money and Payment Services Inc. OpenCart Virtual POS Module allows Signature Spoofing by Improper Validation.

This issue affects OpenCart Virtual POS Module: from 26.8.2 before 26.9.1.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-347

Tecnología: No especificado

Publicado el: 2026-10-09

CVE-2026-86405

Descripción: Improper verification of cryptographic signature vulnerability in Sipay Electronic Money and Payment Services Inc. PrestaShop Virtual POS Module allows Signature Spoofing by Improper Validation.

This issue affects PrestaShop Virtual POS Module: from 26.8.1 before 26.9.1.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-347

Tecnología: No especificado

Publicado el: 2026-10-09

CVE-2026-108107

Descripción: PHPNuxBill through 2025.3.20 contains an unauthenticated SQL injection vulnerability in the radius.php FreeRADIUS REST endpoint that interpolates request parameters into whereRaw() queries. Attackers can send crafted username, macAddr or nasid parameters to the accounting or authenticate actions to extract customer records and credentials via time-based blind SQL injection.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-10-09

CVE-2026-104732

Descripción: The Advanced IP Blocker plugin for WordPress is vulnerable to Authentication Bypass in all versions up to, and including, 8.13.13 The vulnerability exists because `handle_login_action()` performs no server-side check — via transient, session marker, or equivalent — that a requester completed step-1 password authentication before processing a step-2 TOTP submission for the POSTed `user_id`; comp...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-10-10

CVE-2026-107645

Descripción: The Blocksy Companion plugin for WordPress is vulnerable to privilege escalation in versions up to, and including, 2.1.58 This is due to the implement_user_registration() AJAX handler explicitly disabling Dokan's vendor-registration nonce check (via add_filter('dokan_register_nonce_check', '__return_false')) and then trusting an attacker-supplied $_POST['role'] value when invoking wc_create_new...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-10-10

CVE-2026-94589

Descripción: The Extensions For CF7 (Contact form 7 Database, Conditional Fields and Redirection) plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 3.4.5 via the extcf7_submit function. This is due to missing file extension, MIME type, and size validation in the signature field's validation_filter(), combined with the absence of PHP-execution guards in the upl...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-10-10

CVE-2026-103889

Descripción: The 3D Product configurator for WooCommerce plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 2.16.2 via the 'xpv_image' parameter parameter. This is due to missing authentication and nonce checks on the wp_loaded handler combined with no sanitization of the xpv_image POST parameter before it is echoed unescaped into a Dompdf-rendered HTML templat...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-10-10

CVE-2026-97670

Descripción: The Avada (Fusion) Builder plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 7.16.1. This is due to the plugin not properly verifying authorization before dispatching a WordPress action hook whose name is taken from an attacker-supplied form-field value (via the notification email_message [field] placeholder and the {action_hook,...} dynamic-data t...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-10-10

CVE-2026-104801

Descripción: The PPOM – Product Addons & Custom Fields for WooCommerce plugin for WordPress is vulnerable to arbitrary file deletion due to insufficient file path validation in the rename_files function in all versions up to, and including, 34.0.10 This makes it possible for unauthenticated attackers to delete arbitrary files on the server, which can easily lead to remote code execution when the right file ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-10-10

CVE-2026-104803

Descripción: The WPCOM Member plugin for WordPress is vulnerable to Authentication Bypass in all versions up to, and including, 1.7.27 via the `uuid` and `code` parameters of the social-login callback handler registered on the `init` hook. The vulnerability exists because the `login` function's social-login flow performs no nonce validation, no OAuth state verification, and no per-visitor namespace isolatio...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-10-10



CVE-2026-108551

Descripción: openapi-typescript-codegen through 0.31.0 contains a code injection vulnerability that allows attackers controlling an OpenAPI document to inject JavaScript by supplying unescaped values interpolated into single-quoted string literals. Attackers can embed a single quote in path keys, parameter names, servers[0].url, or info.version to execute arbitrary JavaScript when generated clients are impo...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-10-10



Resumen del Reporte

CVEs analizados: 24

Promedio CVSS: 9.35

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat

